

**Policy\_ID: CIP-GPS-001**

**Policy\_Name: Global Data Privacy and Regulatory Compliance Statement**

**Version: 2.1**

**Effective\_Date: 2026-01-01**

**Risk\_Category: Legal & Compliance**

**Applicable\_Regulations: [GDPR, CCPA/CPRA, HIPAA, DPDPA 2023, UK DPA 2018]**

**Owner: Data Protection Office (DPO)**

# **Global Data Privacy & Regulatory Compliance Statement**

## **1. Introduction [Risk Score: 1]**

Capstone Inc. ("Capstone") is committed to ensuring that all data processing activities comply with applicable global privacy regulations. This Compliance Statement outlines the legal, procedural, and technical controls governing the collection, processing, storage, transfer, and disposal of personal data.

## **2. Regulatory Framework [Risk Score: 5]**

Capstone's data protection program is mandatorily aligned with the following regulations. Failure to adhere to these frameworks constitutes a critical compliance breach.

- **GDPR (EU 2016/679) & UK-GDPR:** Primary basis for global privacy alignment.
- **CCPA/CPRA (California):** U.S. privacy obligations for residents.
- **HIPAA (U.S.):** For applicable healthcare data processing.
- **Indian DPDPA 2023:** Regulatory foundation for Indian operations.
- **LGPD (Brazil) & PIPEDA (Canada).**

**Non-Compliance Impact:** Violation of regulatory frameworks may result in fines up to 4% of global turnover, legal sanctions, and immediate contract termination.

## **3. Data Subject Rights [Risk Score: 4]**

Capstone supports the following rights globally. All requests must be processed within the

statutory timeline (default: 30 days).

1. **Right to Access:** Individuals may request a copy of their data.
2. **Right to Rectification:** Correction of inaccurate information.
3. **Right to Erasure ("Right to be Forgotten"):** Subject to legal constraints.
4. **Right to Restrict Processing:** In specific conditions.
5. **Right to Data Portability:** Structured, commonly used formats.

**Non-Compliance Impact:** Failure to honor Subject Rights within SLAs (30 days) is a **High Risk** violation resulting in regulatory reporting and potential litigation.

## 4. Cross-Border Data Transfer [Risk Score: 5]

Capstone ensures lawful data transfers through:

- **Standard Contractual Clauses (SCCs)** for EU/EEA transfers.
- **UK International Data Transfer Addendum (IDTA).**
- **Transfer Impact Assessments (TIA)** for transfers to high-risk jurisdictions.

**Non-Compliance Impact:** Unauthorized cross-border transfers are a **Critical Risk** (Score 5). Transfers without a valid legal basis (SCC/TIA) are strictly prohibited.

## 5. Data Security & Governance [Risk Score: 5]

To protect personal data, the following controls are mandatory:

- **Encryption:** AES-256 for data at rest; TLS 1.2+ for transit.
- **Access Control:** MFA enforcement for all privileged accounts.
- **Monitoring:** SIEM monitoring with real-time alerting.

**Non-Compliance Impact:** Storing personal data in cleartext or sharing it over unencrypted channels is a **Critical Risk**.

## 6. Retention & Deletion [Risk Score: 3]

Data must be retained only for the defined periods:

- **Client Project Data:** 7 years post-contract.
- **HR Data:** 10 years post-employment.
- **Security Logs:** 7 years.

**Non-Compliance Impact:** Keeping data beyond the retention period or deleting it prematurely is a **Medium Risk** operational violation.

## 7. Breach Management [Risk Score: 5]

Regulatory notification timelines must be strictly followed:

- **72 Hours:** GDPR / UK-GDPR.
- **30 Days:** Certain U.S. State Laws.
- **48 Hours:** Industry-specific mandates.

**Non-Compliance Impact:** Failure to report a breach within 72 hours is a **Critical Risk** triggering maximum regulatory penalties.